

Assessment Cover Sheet

Unit Code and Title	ICT942 Cybersecurity Project Semester 2 2026
Assessment Name and Number	Assessment 2
Teaching Period / Year	Semester 2/ 2026
Lecturer / Unit Coordinator	Professor Md Ashraf Uddin
Students Full Names	Charity Gwese, Sonam Pelden, Rikesh Aryal, Zubair Adil Soomro
Submission Date	13/09/2026
Submission Type	☐ Individual ☒ Group

Members (Complete ONLY for group assessments)

Student Name	Student ID	Contribution (%)	Responsibilities for the Assessment
Sonam Pelden	CIHE23321	25%	Introduction, Project Planning, Architecture
Charity Gwese	CIHE250948	25%	Industry Analysis, PoC Description
Rikesh Aryal	CIHE251435	25%	Solution Design/Tech Justification/security design/ threat model/cost estimation.
Zubair Adil Soomro	CIHE250922	25%	Sprint Plan, PoC evidence, Testing/Validation/Cybersecurity Evaluation, Conclusion, Executive Summary

Declaration

By submitting this assessment, I/we confirm that this work is my/our own and complies with the CIHE Academic Integrity Policy and the QA70 Use of GenAI in Teaching, Learning, Assessment and Research Policy. Any use of AI or other tools has followed the assessment instructions and guidance provided in the CIHE Student Guide on the Use of AI and has been fully acknowledged in the AI/Tool Use Declaration Table below. I/we understand that inappropriate or unacknowledged use of AI, or submission of work that is not my/our own, may constitute academic misconduct. I/we also confirm that this assessment has not been previously submitted unless approved, and I/we consent to its use for standard academic integrity, quality assurance, and AI governance review processes.

Student(s)

Signature:

Date:

GenAI Tool	Description
Chat GPT	Assist with brainstorming, understanding terms, formatting and structure

Contents

Executive Summary	4
1. Introduction	5
1.1 Business Context and Problem Statement.....	6
1.2 Project Goals, Objectives, and Success Criteria	7
1.3 Project Scope, Assumptions, and Constraints	8
1.4 Stakeholders and User Requirements.....	9
2. Project Planning and Management	10
2.1 Project Charter.....	10
2.2 Project Roadmap / Gantt Chart	10
2.3 Team Roles and RACI Matrix.....	11
2.4 Risk Register	12
2.5 Feasibility Study.....	13
3. Industry and Technology Landscape Analysis.....	14
3.1 Current State Assessment: As-Is Analysis.....	14
3.2 Technology and Market Survey	15
3.3 Comparative Analysis of Existing Solutions.....	16
3.4 Gap Analysis: As-Is to To-Be.....	18
4. Solution Design.....	19
4.1 Proposed Solution Architecture.....	19
.....	20
4.2 Technology Stack and Justification	20
4.3 Security Design and Control Mapping.....	22
4.4 Capital and Non-Capital Cost Estimation	25
5. Proof of Concept, and Evaluation.....	26
5.1 Sprint Plan	26
5.2 Testing, Validation, and Cybersecurity Evaluation	29
Table 1 — Functional Test Evidence (executed, Week 8).....	32
Table 2 — Threat → Asset → Vulnerability → Impact → Control.....	32
Table 3 — NIST Cybersecurity Framework 2.0 Mapping	34
Table 4 — Before / After Risk Comparison.....	34



6. Conclusion and Recommendations.....	35
References.....	36
Appendix.....	38

Executive Summary

FAZ Australia's clinical messaging platform, MedTalk Connect, shares data with external Electronic Medical Record (EMR) systems like Halo Connect and Oracle Health Millennium. Now engineers check these connections using one-off tests that run close to or sometimes against live clinical environments. This approach brings three risks. First there is a clinical-safety risk if an incorrect connector update or a bad data payload makes it into a patient record. Second there is a privacy risk under the Privacy Act 1988 (Cth) and the My Health Records Act 2012. And third there is a compliance risk because there is no way to prove that SNOMED CT-AU ICD-10-AM and MBS coding mappings are working as expected.

This project introduces a Healthcare Integration & Clinical Terminology Test Harness: a synthetic and isolated environment where engineers can test how connectors behave and how clinical terminology mappings work—without ever using real patient data. Stage 1 produced the trust-boundary architecture, a planned two-sprint implementation approach, seven planned failure-mode test cases and eight data-validation rules, alongside a limited working Postman proof of concept.

A working proof of concept has turned this idea from theory into practice. A synthetic FHIR R4 Patient endpoint was tested in Postman. It returned the expected response and a synthetic identifier in two out of three tests. On the test it correctly exposed a configuration issue—a missing FHIR-specific content type. That shows the testing process finds defects not just confirms success.

Security and privacy controls have been aligned with the NIST Cybersecurity Framework 2.0. Data isolation has been partially demonstrated. Authentication, access control and continuous monitoring are mentioned in the design. They are part of the plan and were not shown during the Stage 1 PoC. These features are still scheduled for Stage 2. The biggest unresolved concern is that automated mapping between SNOMED CT-AU and ICD-10-AM is inherently unreliable—some published sensitivity figures are as low as 54%. That's why consistent synthetic testing is essential before any connector touches production data.

For FAZ Australia leadership the business case is clear. Now production evidence depends on only one reference deployment. A targeted Stage 2 implementation effort would bridge that gap, help meet the platform's own production-readiness checklist. It would also reduce the chance of an error, a privacy breach or a billing-coding problem as MedTalk Connect grows.

1. Introduction

MedTalk Connect, the interoperability layer developed by FAZ Australia, currently has no method to reliably test or validate FHIR-enabled data exchange and clinical terminology mapping with the EMRs that MedTalk Connect interfaces with, prior to implementation into production (FAZ Australia, 2026b). This gap presents a direct cybersecurity, privacy and clinical-safety issue because as systems change, connector and terminology-mapping changes are informally tested with systems near to or overlapping with real clinical data; this is not in line with obligations under the Privacy Act 1988 (Cth) and the My Health Records Act 2012 (Cth).

This is important because MedTalk Connect is located between an AI-generated clinical note and a patient's medical record any error in FHIR exchange or in the translation of the clinical note from SNOMED CT-AU to ICD-10-AM/MBS could lead to incorrect clinical documentation or billing, while any chance of real patient data being accidentally exposed during testing constitutes a reportable privacy breach. Addressing this, the Healthcare Integration & Clinical Terminology Test Harness project will be designing and subsequently build, a fully synthetic FHIR R4 test environment aligned with the AU Core Implementation Guide (HL7 Australia, 2025) that enables safe and repeatable testing of interoperability and terminology mapping.

As part of this, the project directly lowers the cybersecurity and compliance risk for FAZ Australia, elevates MedTalk Connect's security stance in the context of data exchange, enhances operational efficiency by eliminating reliance on production adjacent testing, and builds business resilience by providing the FAZ Australia with a reusable validation asset before it begins with new EMR connectors and practices.

1.1 Business Context and Problem Statement

FAZ Australia is a Canberra-based health technology, with its flagship product MedTalk, an artificial intelligence clinical scribe tool that is used by doctors in clinics all over Australia to turn doctor–patient conversations into structured clinical notes. MedTalk integrates with practice EMR systems via MedTalk Connect, a white label interoperability layer based on the HL7 FHIR standard, which currently supports Oracle Health Millennium and Best Practice/Halo Connect at production and supports Epic in sandbox.

Currently MedTalk Connect does not provide for a secure and safe environment to validate data exchange with EMR systems, or validate clinical terminology mapping between SNOMED CT-AU, ICD-10-AM and Medicare Benefits Schedule (MBS) coding. Some new connectors and FHIR terminology mappings are subject to informal validation with ad hoc scripts and manual review of FHIR payloads in some environments sufficiently similar to production that they pose a real data risk. This puts the organisation at risk of clinical-safety, privacy and compliance issues with the Privacy Act 1988 (Cth) and the My Health Records Act 2012 (Cth) and delays the adoption of new connectors and practices.

The size of this problem is illustrated by the quantified evidence from Stage 1 analysis: there is no repeatable process to validate terminology mapping, and the error-handling behaviour (slow responses, malformed data and dropped connections) is not systematically tested with a significant risk of undetected errors affecting real clinical scenarios, especially for Epic (sandbox-only); and test coverage varies widely by connector maturity, with Epic (sandbox-only) receiving significantly less validation than the two production-grade connectors.

This project aims to solve the problem by creating the FHIR test harness, a fully synthetic standard based test harness that will allow FAZ Australia's engineers to test interoperability and terminology translations without the involvement of real patient data (Stage 1) and constructing the FHIR test harness (Stage 2). The project directly lowers cybersecurity and privacy risk, enhances the organisation's security around data exchange, boosts efficiency by eliminating reliance on production-adjacent testing, and helps ensure adherence to Australian privacy and health-data laws and, of course, speeds MedTalk Connect's development and onboarding process.

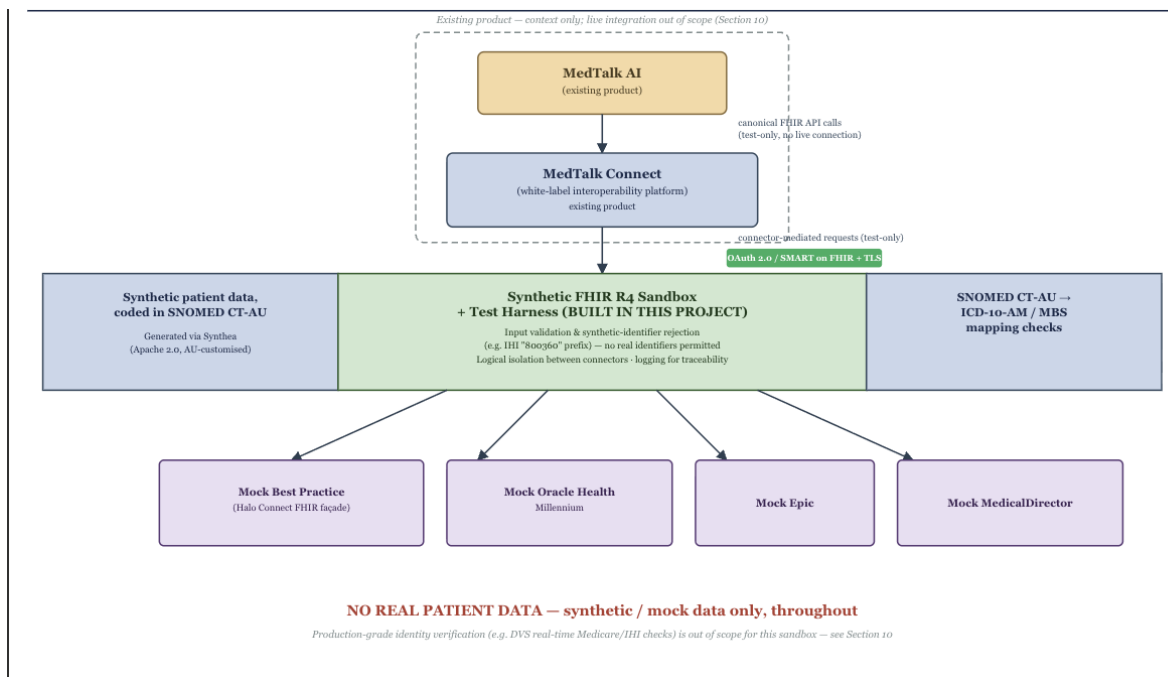


Figure 1.1.1: System context Diagram.

1.2 Project Goals, Objectives, and Success Criteria

Project Goals: Design and validate a synthetic, standards-based FHIR test harness to help FAZ Australia to safely test interoperability and clinical terminology mapping between MedTalk Connect and the FHIR standard before going to production to protect patient data.

SMART Objectives:

- By end of Stage 1, create a synthetic FHIR R4 test environment that supports MedTalk Connect's EMR connectors for production (Oracle Health Millennium and Best Practice/Halo Connect) and sandbox (Epic), and can be validated with peer review by mentors.
- Create and test a model for mapping a defined synthetic dataset of 50 patient records with 3 clinical conditions between the SNOMED CT-AU and ICD-10-AM coding systems, including against expected results, including edge cases.
- Produce a written test plan for normal, error handling and degraded connection to implement and execute in Stage 2 (slow response, malformed data, drop connections).
- Fully avoid real patient data during the project, with all use of real patient data blocked by automatic validation rules for synthetic data (e.g., Luhn check rejection of realistic identifiers).

Measurable Success Criteria:

- Architecture diagram of the test harness reviewed and approved by the industry mentor.

- A synthetic test-data plan generated and validated, representing a variety of patient scenarios coded in SNOMED CT-AU and with corresponding ICD-10-AM/MBS translations.
- A written, connector-weighted test plan covering happy-path, error-handling and degradation scenarios for all three connectors.
- All test data were synthetic, and there were no real patient identifiers at any point.

1.3 Project Scope, Assumptions, and Constraints

In Scope:

- Design of a synthetic FHIR test harness for REST/JSON FHIR exchanges, where applicable, HL7v2 messaging and SMART on FHIR (OAuth 2.0) authentication, according to the AU Core FHIR Implementation Guide.
- Design level mapping logic for the translation of SNOMED CT-AU → ICD-10-AM for a representative set of synthetic clinical scenarios.
- Test-data plan and written test plan (functional, negative/error-handling and performance-style scenarios) of connectors defined in FAZ Australia's Connector Catalogue based on connector maturity.

Out of Scope:

- Implementation or coding of the test harness (extended to Stage 2).
- Use of real patient data or connection to real production EMR environments.
- This project is about interoperability and not about the functionality of the scribe, it's not about changes to the core AI transcription/NLP engine of MedTalk.

Assumptions:

- Halo Connect will publish a specific set of FHIR resources/endpoints that are enough for the test harness to exchange data.
- The mapping logic to map SNOMED CT-AU to ICD-10-AM/MBS agreed in Stage 1 is correct, because the wrong mapping would result in misleading outcomes of the test.
- The test harness will also be able to simulate and detect good, bad, and dropped/slow responses to ensure its robustness.

Constraints:

- Stage 1 is limited to requirements, analysis and design under a waterfall approach; the proposed design is not validated through implementation until Stage 2, which will follow Agile/Sprint delivery per mentor guidance.
- No budget or cloud services are provided by either the client or the College; the team is limited to open-source tools and free-tier hosting.
- The test harness consists entirely of synthetic patient records and, if not designed carefully, may not represent the richness of actual clinical information.
- Delays in receiving FHIR, Halo Connect, or other connector documentation and specifications from FAZ Australia could delay design finalisation and testing milestones.

1.4 Stakeholders and User Requirements

Table 1.4.1: Stakeholders

Stakeholder	Role	Interest	Influence
Atif Nisar (FAZ Australia)	Project Sponsor / Industry Mentor	High	High
Md Ashraf Uddin	Academic Supervisor	Medium	High
Project Team (Sonam, Charity, Rikesh, Zubair)	Delivery Team	High	High
MedTalk Connect Engineering Team	End users of the test harness	High	Medium
Medical Practices (Best Practice / Oracle Health users)	Indirect beneficiaries	Medium	Low
EMR Vendors (Oracle Health, Best Practice/Halo Connect, Epic)	Technical interface owners	Medium	Medium

Functional and Non-Functional Requirements Summary:

- Security requirements: Control access of authorized test environment users; ensure tenant isolation to limit exposure of data from cross-connector or cross-tenant.
- Privacy needs: Only use synthetic patient data, with automated validation (e.g., Luhn-check rejection) to prevent accidental use of real identifiers
- Usability requirements: Users should be able to perform tests and understand the results without requiring extensive technical expertise, and in a few simple steps.
- Scalability requirements: Have a specific, scalable synthetic data set (for the first few years – at least 50 records on 3 conditions without redesign).
- Performance criteria: Under normal test conditions, return standard test results in an acceptable response time.
- Compliance requirements: Ensure the harness does not process real patient or health information and align with the Privacy Act 1988 (Cth), My Health Records Act 2012 (Cth) and the AU Core FHIR Implementation Guide.

2. Project Planning and Management

2.1 Project Charter

Project Purpose: Develop and provide a synthetic, standards-based FHIR test harness, to help FAZ Australia test MedTalk Connect's interoperability and clinical terminology mapping without real patient data.

Project Scope: Architecture design, terminology mapping logic (SNOMED CT-AU to ICD-10-AM to MBS); and a written test plan for the 3 EMR connectors (Stage 1); build and demonstration of the harness (Stage 2).

Key Stakeholders: Atif Nisar (FAZ Australia, Project Sponsor/Industry Mentor), Md Ashraf Uddin (Academic Supervisor), Project Team, MedTalk Connect Engineering Team, Connected EMR Vendors.

Key Deliverables: Architecture diagram; synthetic test-data plan; written test plan for happy path, error handling and degradation scenarios; feasibility and risk analysis; working proof-of-concept test harness (Stage 2).

Acceptance Criteria: Architecture is reviewed and approved by the industry mentor, test-data plan is validated to provide representative SNOMED CT-AU scenarios, test plan includes all three connectors, weighted according to the maturity, with zero real patient data used at any stage.

Project Authority: The scope changes, stage-gate deliverables are approved by Project Authority comprising Md Ashraf Uddin (Academic Supervisor) and Atif Nisar (Industry Mentor).

Expected Business Value: Clinical-safety and compliance risk minimised, speeds up connector onboarding, and provides the business with a reusable CI/CD testing asset for FAZ Australia.

2.2 Project Roadmap / Gantt Chart

Table: 2.2.1: Project Roadmap

Phase	Weeks	Key Milestone
Requirements & Charter	1–2	Charter, stakeholder analysis, business/problem analysis approved
Requirements Elicitation & SRS	3–4	Functional/non-functional requirements and use cases signed off
Feasibility & Risk Analysis	5	Risk register, feasibility study, mentor sign-off (Stage 1 complete)
Report Drafting (2A/2B)	6	Sections 1–3 drafted; architecture diagram started

Solution Design & PoC Planning	7	Sections 4–6 drafted; sprint plan finalised; first full draft compiled
Finalisation & Submission	8	References, proofreading, slides, rehearsal; submission by 13 Sept

2.3 Team Roles and RACI Matrix

Table 2.3.1: Team roles

Deliverable	Sonam (Lead/Arch.)	Charity (Clinical)	Rikesh (Integration)	Zubair (Testing/Docs)
Project Charter & Planning	R/A	C	C	I
Business/Clinical Context (1.1–1.4)	A	R	I	I
Industry & Technology Analysis (Ch. 3)	C	R (3.1)	R/A (3.2–3.4)	I
Solution Architecture (4.1–4.2)	R/A	I	C	I
Security Design & Cost (4.3–4.4)	C	I	R/A	C
Proof of Concept & Evaluation (5.1–5.2)	I	C	C	R/A (5.1, 5.2)
Final Report Compilation	A	C	C	R
Presentation Delivery	A	R	R	R

R = Responsible, A = Accountable, C = Consulted, I = Informed.

Sonam holds overall accountability as Project Lead, chairing check-ins and resolving scope conflicts; Charity leads clinical-data accuracy decisions; Rikesh leads technical/integration trade-offs; Zubair leads quality assurance and documentation standards. Leadership was distributed by domain rather than centralised, which kept decisions close to the person with the relevant expertise and reduced review bottlenecks going into Stage 2.

2.4 Risk Register

Table 2.4.1: Risk Register

ID	Risk	Likelihood	Impact	Score	Rating	Response	Owner
R1	Undetected connector crash/hang on slow FHIR response (>5s)	Medium	High	6	High	Automated slow-response test with timeout/retry validation	Zubair
R2	Unhandled parser exception from invalid HL7 segment	Medium	High	6	High	Automated malformed-HL7 rejection test	Zubair
R3	Malformed FHIR data accepted and written to clinic system	Medium	High	6	High	Automated malformed-FHIR validation test	Zubair
R4	Cross-tenant data leakage via missing tenant scoping	Low	Critical	4	High	Row-level tenant isolation, gateway validation, dedicated test layer	Zubair
R5	Real patient identifier accidentally used in synthetic dataset	Low	Critical	4	High	Luhn-check rejection rule + automated negative test	Zubair
R9	Team's limited healthcare-semantics experience delays build	Medium	Medium	4	Medium	Curated SNOMED subset, weekly mentor guidance	Team

R10	Scope creep from broad project brief	Medium	Medium	4	Medium	Fixed endpoint list, agreed exclusions	Team Lead
-----	--------------------------------------	--------	--------	---	--------	--	-----------

Score = Likelihood × Impact (Low=1, Medium=2, High=3, Critical=4). The register carries forward all ten risks identified in Stage 1, condensed here to the highest-scoring items. High/Critical risks (R1–R5) directly threaten clinical safety, data integrity or privacy and are mitigated through automated test cases tied to specific failure modes; Medium risks (R9–R10) are operational and are managed through scope discipline and mentor engagement rather than technical controls.

2.5 Feasibility Study

Technical feasibility is high: the proposed stack (FHIR R4 (Health Level Seven International, 2019), AU Core (HL7 Australia, 2025), HL7 v2.4 (Standards Australia, 2007), SNOMED CT-AU, HAPI FHIR, FastAPI/Node.js, PostgreSQL, Docker) is mature, open-source, and familiar to the team. The key difficulty is correctly implementing healthcare-specific semantics rather than tool availability

Operational feasibility is medium-high: Mentor commitment is confirmed; Reference architecture documents; Team tooling (GitHub, Jira & Teams) is established for delivery. Primary operational risk is from competing demands other University Units, addressed in a Team Working Agreement.

Economic feasibility is high: estimated overall cost is around \$150 AUD, both using open source tools and free tier hosting under the WIL arrangement, and the expected value for FAZ Australia is great, as defect escape rate will be reduced and onboarding of connectors will be accelerated.

Legal feasibility is high: the project also doesn't include real patient data, which is the primary exposure under the Privacy Act 1988 (Cth) and My Health Records Act 2012 (Cth). Automated synthetic-data validation rules (such as Luhn-check rejection) offer technical protection, but do not require manual compliance.

Ethical feasibility is high: the design poses no risk of actual harm to patients as a result of construction as no actual clinical data are ever processed. Other ethical issues include the ethical use of AI for creating and verifying synthetic clinical scenarios, and the appropriate mapping of the terminology without inadvertently introducing coding errors into the downstream billing or clinical use.

Cybersecurity feasibility is high: as each identified threat is reduced to a Low residual risk by the following layers of controls: tenant isolation, rate limiting, structured error handling, and immutable audit logging, which are validated by automated test cases as opposed to assumptions.

The project is feasible across all six dimensions, the biggest risk is the team's learning curve with FHIR/SNOMED, this is addressed by limiting the scope of the data set at the start of the project and reviewing data with the mentor weekly.

3. Industry and Technology Landscape Analysis

3.1 Current State Assessment: As-Is Analysis

Faz Australia Flagship product is MedTalk. MedTalk is an artificial intelligence clinical documentation that listens to doctor-patient consultation producing a live transcription during the consultation. MedTalk connects to clinical systems or Best Practice (BP) where the completed EMR (electronic medical record) is stored and shared to other systems exposing integration interfaces via FHIR (Fast Healthcare Interoperability Resources). Halo Connect handles transformation of FHIR data to underlying systems formats. The EMR is coded using SNOMED CT-AU (Systematized Nomenclature of Medicine – Clinical Terms – Australian Extension) which is the Australian standard of comprehensive clinical vocabulary used in electronic health records. The EMR coded with SNOMED CT-AU is then mapped ICD-10-AM (International Statistical Classification of Diseases and Related Health Problems, Tenth Revision, Australian Modification) using MedTalk Internal Infrastructure. For billing purposes MedTalk partners with MediBetter BOSS (Billing Optimisation and Support Software) by sharing the translated ICD-10-AM to be mapped to the MBS (Medicare Benefits Schedule) system (MediBetter, 2026).

Faz Australia also utilise the HL7 FHIR R5 (Fast Healthcare Interoperability Resources) and SMART on FHIR protocols to test, map and synchronise data to the BPs exact data architecture that it is being integrated to (MedTalk AI, 2020). One of the developing platforms that MedTalk uses is Epic. Epic sandbox provides platform for developers to test integration first using mock patient data before EHR (Electronic Health Records) exchange. According to Choudhary (2026), for a company to upload their application on Epic is split into three main categories for charging fees. There is Connection Hub listing fee approximately USD\$500, vendor services membership charging up to USD\$1 900 and build Labour ranging from USD\$40000 for read only FHIR and USD\$350000 for full bidirectional (Choudhary, 2026). MedTalk and MediBetter partnership tech-tech API prices are not publicly available but according to MarkiTech.AI (2025), a flat fee ranges from \$100 to \$500. This excludes the subscription of the MediBetter professional suite which unlocks the BOSS engine and browser extensions for clinical workflow. These integration and subscription costs represent a significant financial pain point for MedTalk, focusing on the high upfront investment required for full bidirectional FHIR integration with Epic. These costs burden the scalability of Medtalk.

Apart from the financial burden on Faz Australia, the main operational inefficiency is lack of a reusable safe test environment. The restricted access to sandboxes slows development and harder to reproduce issues consistently to improve MedTalk overall. Due to strong privacy and compliance requirements, there is also limited flexibility in testing live connection with other BPs since Epic requires the application to be load on first to test it. These limitations clearly indicate the business pain on high costs in expansion, delayed integration tests and higher compliance exposure if problems are found late. These pain points are affecting engineering efficiency and confidence in releases, which this project of a test harness is designed to solve.

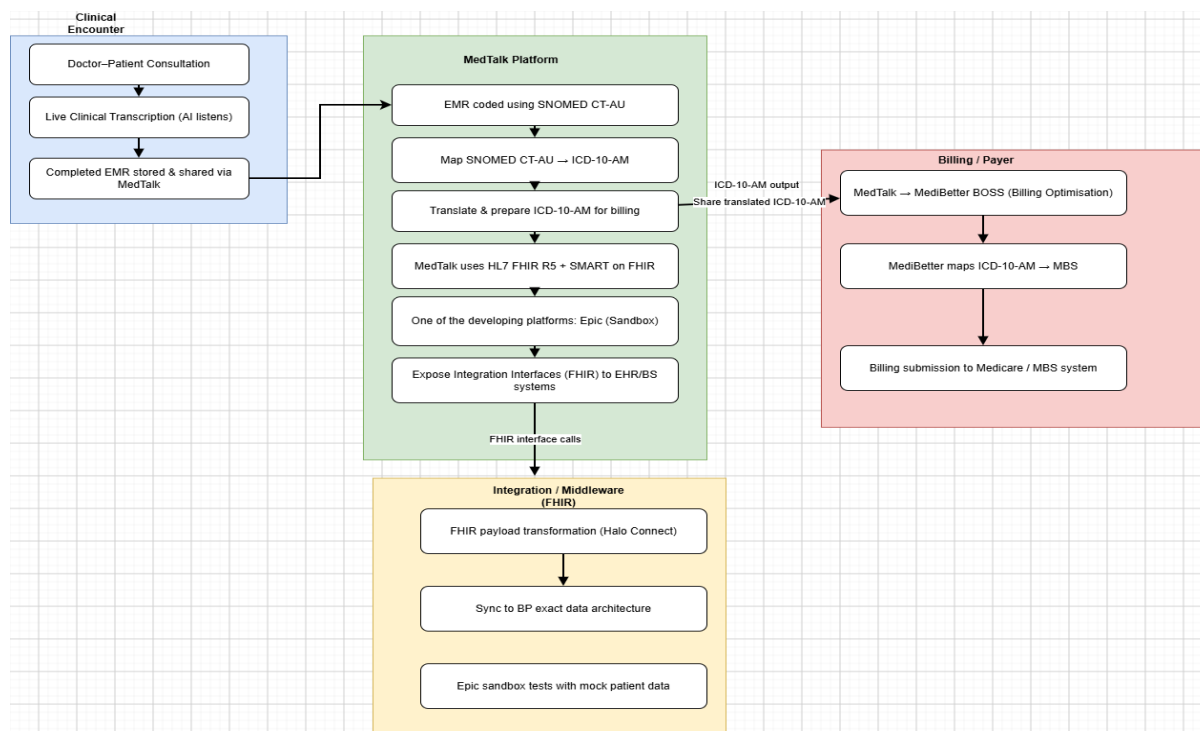


Fig 3.1.1 Current AS-IS flow

3.2 Technology and Market Survey

MedTalk is part of the Australian health interoperability market. The main technical challenge in this market is not only generating accurate clinical notes but safe exchange of the clinical notes and correct translation of the data to the receiving system. The most relevant technologies for the test harness are HL7 FHIR, SMART, vendor integration layers and Australian clinical terminology. These are all essential for the project as it has to reflect the same standards as production systems.

FHIR (Fast Healthcare Interoperability Resources) is the central exchange standard that defines resources meaning patient data, appointments, clinical notes and related information structure and transferred between systems (eCQI, 2025). It also depicts interaction patterns including real time representation state Transfer (RESTful) application programming interfaces (APIs), document based and messaging. The RESTful APIs use HTTP operations to create, read, update and search for FHIR resources to enable real time data exchange. FHIR framework is free to build commercial and open-source tools while HL7 is registered trademark that cannot be used without permission. FHIR is a necessity for the project to mimic structured clinical document exchange and be able to test it.

Australian clinical terminology and classification is vital which include SNOMED CT-AU and ICD-10-AM. SNOMED CT-AU is the preferred clinical terminology in Australia which is an extension of the global SNOMED CT standard. It combines international core clinical data with Australian-specific terms, spellings, local reference sets and the Australian Medicines Terminology (AMT). SNOMED CT-AU contains numerous clinical concepts organized into hierarchies like body structures, procedures and clinical findings. SNOMED CT-AU is then mapped to ICD-10-AM which is classification of diseases and diagnosis tailored to match

Australian clinical terminology, practice and health-tracking need. The ICD-10-AM is mapped to MBS for billing in Australia. These terms need to be coded in the synthetic patient record correctly as the test harness will validate them. These terminologies are free access to code in synthetic data.

Synthea is currently one of the most credited synthetic patient generator as it creates realistic realistic mock medical histories and electronic health records lifespan from birth to death. Synthea is an open source but produces mock patients based on Unites States of America demographics. CSIRO have created Australian mock data using Australian demographics, but the synthea tool is not available for public. The mock data is available which would be used for this project to ensure compliance and mimics real clinical system. SMART on FHIR is the authentication and authorising secure system that lets third-party health apps log users in, access electronic health record (EHR) data using standard OAuth 2.0 protocols. This security is necessary to ensure that there is no authorised access to the Test harness.

Vendor integration layers include Halo connect to be implemented in the project. Halo connect is an Australian healthcare platform that safely links local medical practice systems to cloud-based software. It has two main components Halo Link and Halo Cloud. Halo Link is used to link the database to Halo cloud and Halo Cloud would be required for sharing data using standard formats like SQL and FHIR with approved external software. This integration is necessary as when the integration (another system) requires data from the server's database, it sends this enquiry to the Halo Cloud then forwards it to the Halo Link agent. The agent sends the enquiry to the local system database and run the query and send back results.

The main gap in the current market is that existing standards and vendors solve only part of the problem. Standards define how data should be exchanged, vendor products expose endpoints and terminology systems define how meaning should be coded. This still then requires a synthetic test harness that utilises all these tools, standards and frameworks to form a repeatable automation testing, failure simulation and validation of edge cases.

3.3 Comparative Analysis of Existing Solutions

Table 3.3.1 Comparative analysis of existing solutions

Technology	Core Functionality	Deployment Model	Limitations	Relevance to project
SMART Health IT Sandbox	Provides simulated EHR environ for testing HL7 FHIR APIs and OAuth 2.0 authentication and patient data exchange (SMART on FHIR, n.d.).	Cloud based sandbox	Testing in the sandbox does not guarantee compatibility with HER implementation	Partly relevant test FHIR interoperability and SMART on FHIR.
Epic on Epic App Orchard	Developer ecosystem for building and	Cloud/EHR integrated	Integration can involve significant development,	Relevant but does not validate the terminology.

	distributing applications that integrate with Epic EHR. Provides APIs based on HL7 FHIR, testing environments, documentation and integration capabilities (Bonami Software, 2026).		certification and commercial costs. Access is to production data and APIs is restricted.	
MediRecords Developer Sandbox	Provides developers with an environment to test applications and integrations with MediRecords (MediRecords Connect, 2026)	Cloud based developer sandbox	Sandbox data and functionality may differ from the production environment.	Moderately Relevant but does not validate the terminology.
Synapse HealthX innovation sandbox	Provides an innovation and experimentation environment for healthcare technologies, supporting testing, prototyping and validation of digital health solutions and interoperability concepts within a healthcare ecosystem (Synapse, 2023)	Innovation sandbox/ testing environment	Primarily focused on Singapore's healthcare ecosystem different from Australian.	Moderately relevant as a reference model for testing healthcare technologies

The comparison of existing healthcare sandbox platforms demonstrates that solutions such as SMART Health IT Sandbox, Epic on Epic App Orchard, Medi Records Developer Sandbox and Synapse HealthX innovation sandbox provide valuable environments for testing interoperability. Each solution has its limitations in scope of either accessibility or platform dependency. These environments are primarily designed around specific HER ecosystems or organisational requirements rather than providing a vendor neutral solution for comprehensive healthcare integration testing. Medtalk requires an effective test harness that extends beyond basic API connectivity, validation of accurate data exchange and interpretation across the different healthcare systems. This includes validating terminology to ensure that clinical concepts retain their intended meaning between different systems. The proposed Test Harness would be a centralised and independent harness that allows integration of workflows, FHIR resources, authentication, data mapping and terminology validation to be tested before and after

production deployment. The harness would reduce reliance on many vendors for testing multiple components.

3.4 Gap Analysis: As-Is to To-Be

The test harness would address a challenge which includes unsafe or restricted testing versus a reusable fully synthetic test environment. In the current state Medtalk rely on partners, restricted or manual testing to validate integrations. That creates privacy, high financial costs and operational risk because real patient data cannot be used to test during live production. The proposed solution closes this gap by creating a complete (100%) synthetic system that MedTalk connects to, to ensure that all testing occurs without exposing real patient records.

The second gap is basic API connectivity as to standard aligned interoperability. A system can technically send or receive data but still fail to meet Australian expectations if it does not align FHIR, SNOMED CT-AU and ICT-10-AM. This could result in rejected messages and incorrect information shared. The proposed harness address this explicitly by mapping what MedTalk sends and receives using FHIR standard making integration behavior testable and reusable.

The third gap is clinical text generation as to code clinical meaning. MedTalk does not only document doctor patient conversation, but it must also support structured output that can be coded using SNOMED CT-AU and translated where necessary into ICD-10-AM for MBS. The existing integration approach does not provide an independent verification mechanism for consistently detecting semantics that are mismatches or dropped between the layers. The proposed dataset will close this gap by using synthetic records with known terminology mapping and checking the translation outcomes.

The fourth gap is happy path testing as to resilience testing. In real world healthcare integrations fail because of delays, malformed payloads, dropped connections and incomplete data. If failure conditions are not tested before deployment, MedTalk may behave unpredictably when connected to external systems like failed transactions. This requires a testing environment that does repeatable error simulations. The test harness will test robustness by simulating slow systems, bad data and connection loss.

The fifth gap is manual validation as to reusable automation testing. When there is no automation, each release requires human checks which is slow and prone to errors. The proposed solution introduces automatic test suite, making it easy to repeat scenarios, compare results and identify regression. This boosts engineering efficiency and release confidence.

The final gap is fragmented tooling as to a single validation workflow. Existing standards, terminology mapping and vendor interfaces each solve a separate problem, while MedTalk requires a unified controlled environment that brings them all together. Fragmented testing increases complexity and makes it difficult to establish consistent validation processes. The proposed test harness closes this gap by merging standards-based messaging, terminology validation and performing automated testing.

4. Solution Design

This chapter presents the proposed technical solution for the Healthcare Integration & Clinical Terminology Test Harness. The design addresses the cybersecurity and clinical-safety risks identified in the current-state analysis (FAZ Australia, n.d.) by providing a controlled environment for testing interoperability, terminology mapping and connector behaviour without using real patient information. The proposed solution is based on synthetic data, FHIR R4 (HL7 International, 2019), Australian healthcare interoperability requirements (HL7 Australia, n.d.) and simulated EMR integrations. Stage 1 focuses on architecture and design, while implementation and deployment of the complete test harness are planned for Stage 2.

4.1 Proposed Solution Architecture

The solution architecture will be a system architecture comprising the synthetic test data layer, validation and terminology mapping modules, the test execution layer, simulated EMR connectors, and a test reporting module. The architecture of the proposed solution is shown in Figure 4.1.1: Proposed Solution Architecture, while the system context is depicted separately in Figure X: System Context Diagram. Both figures can be found in the project repository.

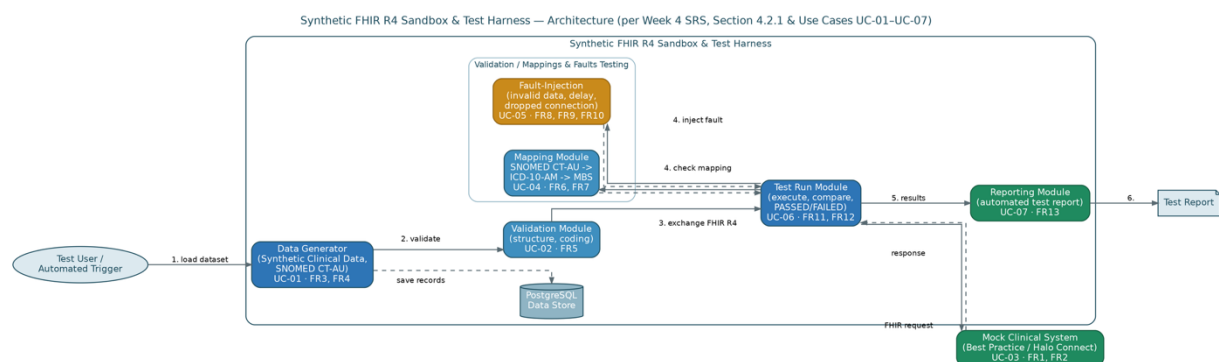


Figure 4.1.1: Proposed Solution Architecture

The primary end-user of the proposed test harness is the authorised MedTalk Connect engineering or testing end-user (e.g. Doctors or clinics as an actors). The end-user creates a test scenario and selects the appropriate connector and test parameters. The system creates synthetic patients and clinical encounter records based on this information (Walonoski et al., 2018). Before these records are used for testing purposes, they go through validation control checks to ensure that they satisfy the necessary synthetic data constraints and do not include any realistic patient identifiers.

Validated data is represented using FHIR R4 objects and passed to the interoperability testing layer (Gruendner et al., 2021). In addition, HL7 v2 messages can be simulated in case it is required. Data will go through the terminology mapping stage, where representative clinical concepts will be mapped on SNOMED CT-AU, ICD-10-AM and MBS (Giannangelo et al., 2012). Repository will provide a special terminology mapping chain that depicts this process.



Figure 4.1.2 Terminology Mapping Chain

Test execution layer performs normal, negative and degraded scenarios. These involve successful message exchange, malformed data, slow responses and dropped connections. The response from test execution layer is evaluated according to the expected outcome and stored for future analysis. Simulated connector layer provides simulated EMR integrations relevant to MedTalk Connect, which will allow testing connector behavior without having to connect the test harness to production clinical systems.

The primary trust boundaries are thus established between the authorized user and the test harness, between unvalidated and validated synthetic data and between internal test environment and simulated connectors. The authentication, access control, data validation, connector isolation and secure communication are proposed as a protection measure at these trust boundaries. Such design allows implementing all the necessary requirements of the project directly.

4.2 Technology Stack and Justification

The technology stack is chosen taking into consideration interoperability standards, needs of Australian healthcare system, security and cheapness of implementation. The selected technologies will enable implementing the Stage 1 architecture, laying a foundation for the Stage 2.

React technology is used as the frontend framework because of the requirement to use the stateful and component-based interface (scenario builder, results of the live test, connector statuses) instead of several static pages; React technology, along with its ecosystem, will enable developing such an interface without paying license costs, which is possible due to the limitations of the project budget. There are both Python (FastAPI) and Node.js (Express) suggested as the backend languages, not as the single option, because any of these frameworks will be able to implement the sandbox FHIR API with equal level of efficiency and community; the actual choice will be decided by the knowledge of the team, not by any technological requirement.

Table: 4.2.1: Technology Stack and Justification

Layer / Standard	Technology / Tool	Purpose	Justification (vs. alternative)
Backend / API	FastAPI (Python) or Express (Node.js)	Implements the sandbox FHIR API and test-harness logic	Mature, well-documented frameworks with strong REST support; either is fine as a starting point
FHIR test server	HAPI FHIR (open source)	Reference server to bootstrap the mock FHIR endpoints	Saves building a FHIR server from scratch; widely used, well-supported reference implementation
Data exchange standard	FHIR R4 (REST/JSON)	Primary standard for healthcare data exchange and interoperability testing	Required for REST/JSON-based interoperability testing; HL7 v2 alone doesn't support this
Implementation guide	AU Core	Shapes FHIR resources to the Australian context	Generic FHIR lacks Australian-specific alignment
Legacy messaging	HL7 v2	Simulates applicable legacy messaging scenarios	Retained only where relevant; FHIR R4 is preferred for the primary workflow
Frontend	React	Builds the test-harness UI (scenario builder, results dashboard, connector configuration)	Component-based structure suits a dashboard with repeating elements (test cards, result rows); large ecosystem and free tooling keep it within the no-budget constraint; plain HTML/JS would require more manual work for the same interactivity
Terminology	SNOMED CT-AU, ICD-10-AM / MBS	Clinical terminology and Medicare/billing mapping scenarios	Required for Australian clinical/billing context; non-AU code sets wouldn't meet project requirements
Auth	SMART on FHIR / OAuth 2.0	Authentication and authorisation for FHIR interfaces	More granular access control than static API keys
Database	PostgreSQL	Stores synthetic patients, conditions, and mappings	Relational integrity suits structured, linked clinical data
Test data	Synthetic data only	All test records	Prevents exposure of real patient data; enables safe, repeatable testing

The combination of FHIR R4 and AU Core is right since the solution needs to check the interoperability in an Australian healthcare environment (HL7 Australia, n.d.). HL7 v2 remains part of the complementary simulation capabilities but not a substitute for FHIR. The terminology standards (SNOMED CT-AU, ICD-10-AM, MBS) serve as the foundation for clinical and billing mapping testing, whereas SMART on FHIR and OAuth 2.0 become the proposed authentication approach (SMART Health IT, n.d.). Docker becomes a Stage 2 implementation technology and not the pre-existing solution due to the scope of work, where no test harness implementation takes place in Stage 1. Postman/Newman becomes part of the solution besides the unit-testing platform since the API validation comes from an external protocol level that the unit testing cannot handle (Gruendner et al., 2021).

4.3 Security Design and Control Mapping

Security will be integrated in the recommended solution using preventive, protective and monitoring controls. The most important prevention control is the utilization of only synthetic patients, which must be created separately from any patient record data. As a long-term prevention mechanism fit for production with actual patient data, the system should integrate with the Document Verification Service (DVS) – the federal government system that verifies the information in the identity documents, such as the Medicare card, on real-time basis from the records of the issuing authority. It is an authentic verification mechanism instead of structural one, since a real identifier can be verified for its actual issuance instead of good formatting. However, in the sandbox of stage 1 where there is no access to DVS, the equivalent testing-time prevention control would be to reject any identifier that matches any real-world identifier prefix/ranges (such as the IHI prefix ‘800360’) and generate identifiers from the synthetic data generator only.

Authentication will be employed for authorised users of the test harness. This would restrict who could define test scenarios, run tests and access their results. Authentication and delegation for FHIR interfaces would be achieved using SMART on FHIR and OAuth 2.0. Secure transfer should be implemented for implemented interfaces to ensure the security of data in transit. Moreover, logical separation is also needed for connectors and test environments. This helps to minimize chances that the test data or results corresponding to one connector is accessed by another connector. Input validation needs to be performed for the FHIR resources and other message formats to identify any mal-formed input data. Test log will help in providing traceability.

For Stage 2, the vulnerability management process should cover the dependency and container checking, secure configuration and updating of the deployed components. The incident response plan will be necessary to specify the containment, investigation and documentation process of any suspicious security events. Backup and recovery controls will be needed for important configuration and test result data.

These controls have been mainly mapped to NIST Cybersecurity Framework (CSF) since its functions of Identify, Protect, Detect, Respond and Recover help establish a definite framework for the suggested cybersecurity controls (National Institute of Standards and Technology, 2024).

Table 4.3.1: Security Design and Control Mapping (section 10 – planning)

Security Control	Proposed Design	NIST CSF Mapping	Status
Authentication	Basic OAuth 2.0 / SMART on FHIR token-based access for FHIR interfaces	Protect	Implemented (basic)
Data protection	Synthetic data only; real-identifier prefix rejection (e.g. IHI '800360') at input	Protect	Implemented (basic)
Encryption	Encrypted transport (HTTPS/TLS) for implemented interfaces	Protect	Implemented (basic)
Input validation	FHIR resource/message format validation before processing	Protect	Implemented (basic)
Logging and monitoring	Test execution and security-event logging for traceability	Detect	Implemented (basic)
Secure configuration	Baseline hardened configuration for application/containers	Protect	Implemented (basic)
Vulnerability management	Dependency and container security checks	Identify / Protect	Planned — Stage 2
Backup and recovery	Backup of configuration and test-result data	Recover	Planned — Stage 2
Incident response	Defined containment, investigation and reporting process	Respond	Documented only (process, not tooling)
Identity verification (production)	DVS-style real-time verification against issuing records (e.g. Medicare/Services Australia)	Protect	Out of scope — future/production only
Privacy/compliance	No real patient data; alignment with Privacy Act 1988, My Health Records Act 2012, AU Core	Identify / Protect	Implemented (basic)

These controls support the project's stated privacy and compliance objectives, including alignment with the Privacy Act 1988 (Cth) (Australian Government, 1988), My Health Records Act 2012 (Cth) and AU Core requirements (HL7 Australia, n.d.).

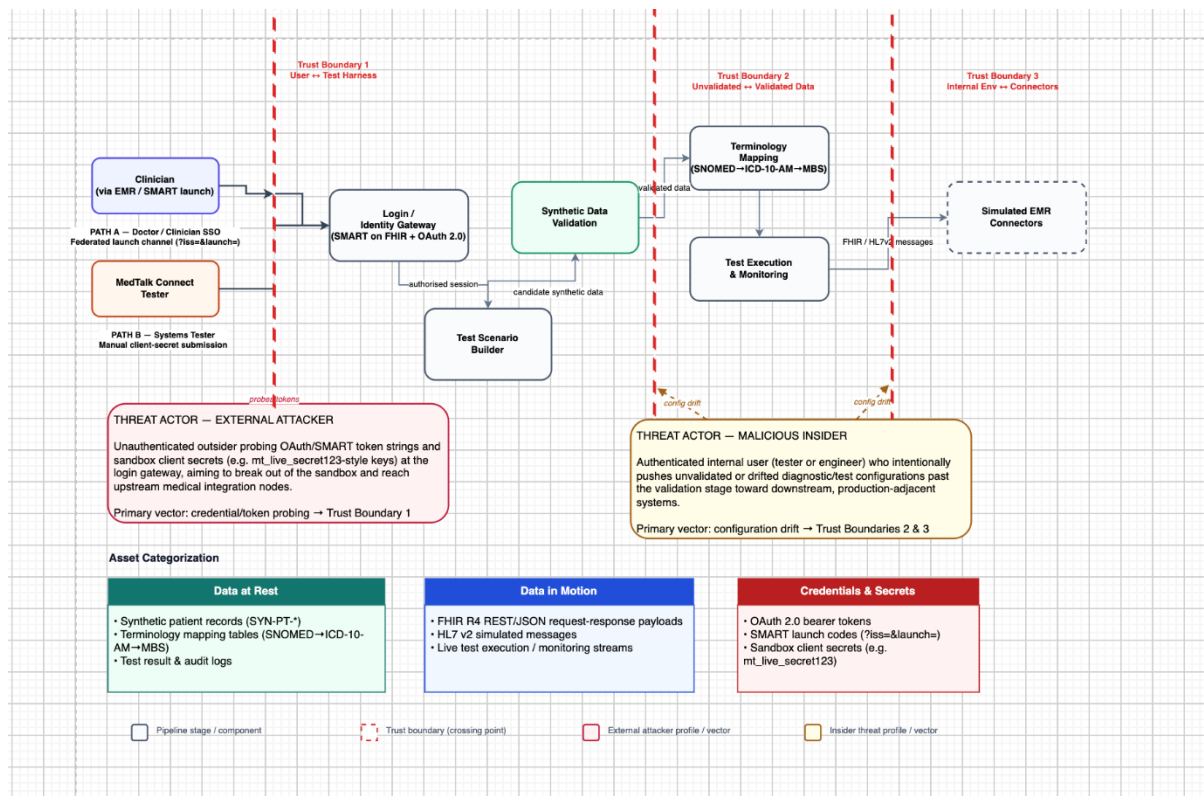


Figure 4.3.1: Threat model

This figure extends the design presented in Section 4.1 by assigning the STRIDE threats across the three trust boundaries that have been defined previously. Clinicians and testers access the design via two separate but authenticated methods: a federated SMART on FHIR launch and a sandbox token login, both traversing Trust Boundary 1 via the identity gateway. The data travels through the scenario building, validating synthetic data (Boundary 2), terminology mapping, and tests, finally arriving at simulated EMR connectors (Boundary 3). The two threat actors used for analysis in the design — an external attacker testing credentials and a malicious insider posing a risk of configuration drift — are represented with vectors pointing at the threatened boundaries. A panel showing asset categorisation lists data at rest, data in transit, and credentials/secrets, and STRIDE matrix (R-01-R-05) is included linking risks with their assets and mitigations as shown in the table below.

Table 4.3.2 Stride Table

ID	Risk Description	STRIDE Category	Boundary	Asset(s) Affected	Mitigation
R-01	Fake or replayed credential reaches the identity gateway	Spoofing	B1	Credentials & Secrets (OAuth token)	SMART on FHIR + OAuth 2.0; short-lived tokens
R-02	Tester's sandbox token reused to perform clinician-only actions	Elevation of Privilege	B1	Credentials & Secrets (sandbox client secret)	Role-based access control; tenant isolation
R-03	Untrusted or drifted scenario/mapping configuration passed downstream	Tampering	B2	Data in Motion (FHIR scenario payload)	Input validation on FHIR resources before execution
R-04	Real-world identifier pattern slips into the synthetic data set	Information Disclosure	B2	Data at Rest (synthetic patient records)	Luhn-check rejection of real AU IHI ranges (e.g. 800360 prefix)
R-05	Malformed or flooded response from a simulated connector	Denial of Service	B3	Data in Motion (FHIR / HL7v2 messages)	Structured error handling; rate limiting; connector isolation

4.4 Capital and Non-Capital Cost Estimation

The solution suggested has an indirect financial impact as stage 1 is related to design, and it can be implemented using only free-tier and open-source tools, according to the report. As stated in the report, there is no budget allocated for any client or College, and there is also no allocation of cloud services, so students must use free-tier and open-source software.

Table 4.4.1: Cost category and estimation

Cost Category	Stage 1 Estimate (AUD)	Future / Stage 2 Consideration	Basis
Development hardware	\$0	\$0–\$2,000 if dedicated hardware is required	Existing team equipment
Software & platform tools (stack, GitHub, Docker)	\$0	\$0, or vendor-dependent if paid tiers are needed	Open-source technologies preferred throughout
Cloud / hosting services	\$0	TBD	Not required for Stage 1; dependent on Stage 2 deployment model
Labor	\$0*	TBD	Student project labour excluded from direct expenditure
Post-deployment (training, maintenance, operational support, scalability)	\$0	TBD	Only relevant after production adoption; not applicable at Stage 1

Labour is not considered as part of the expense for the student project; an organisational implementation will require accounting for labour associated with engineering and support.

The solution will have a number of cost advantages beyond its low cost to implement. For instance, the creation of a synthetic reusable testing environment can limit testing near production and make repeat testing of the connectors possible, while reducing risks of privacy incidents or unknown issues of interoperability. It might also help to decrease testing efforts with the addition of new connectors. But it is not possible to determine a reliable financial return on investment or break-even point, as there is no information about the costs related to testing or incidents in the available project data, labour rates or expected savings of the implementation – the invention of such a number would be inappropriate.

5. Proof of Concept, and Evaluation

5.1 Sprint Plan

The implementation of the Healthcare Integration and Clinical Terminology Test Harness will begin in Stage 2 using a sprint-based approach. Stage 1 has set the business requirements suggested architecture, security design, planned test cases and a small Postman proof of concept. Stage 2 will turn this design into a working test harness. Check it step by step against the success criteria set in Stage 1.

The implementation will be split into two sprints. The first sprint will build the core environment and basic FHIR workflow. The second sprint will add failure simulation, terminology validation, security controls and automated reporting. Jira will be used to track sprint tasks and who's responsible, for them while GitHub will be used for source control pull requests and peer review. During ICT946 Jira sprint logs, task-board records, GitHub evidence and test outputs will be kept. These items may be included in the Stage 2 appendix.

Implementation risks and challenges

Several risks should be addressed before implementation begins. I think these risks might change the feasibility or reliability of the test harness.

Risk / challenge	Potential impact	Planned response
Docker and dependency compatibility across team development environments	Services may run differently on different machines or fail to communicate	Establish a common Docker Compose configuration, fixed versions and container health checks before additional features are added
Incorrect or unrealistic synthetic identifiers	Test records may accidentally resemble real patient information	Apply the planned DVR-01–DVR-08 synthetic-data rules and identifier validation before records enter the test environment
AU Core/FHIR validation complexity	Invalid FHIR resources may pass through the harness or valid	Use HAPI FHIR as the reference validation service and test against agreed AU Core profiles

	resources may be rejected	
SNOMED CT-AU to ICD-10-AM/MBS mapping ambiguity	Incorrect mappings may lead to misleading test results	Use defined synthetic scenarios, expected-result tables, version-controlled mappings and manual review of ambiguous cases
Connector behaviour during slow, malformed or unavailable conditions	Errors may not be handled consistently	Implement the seven planned failure-mode test cases covering slow responses, malformed FHIR/HL7 data, dropped connections and unavailable mock systems
Authentication and tenant isolation not yet implemented	Unauthorised access or cross-tenant exposure could occur in a larger test environment	Implement authentication, authorisation and tenant-scoping controls before multi-tenant testing
Scope growth during ICT946	The team may attempt more connectors and functions than can be tested reliably	Prioritise the Patient workflow, core validation, fault-injection scenarios and defined acceptance criteria before adding optional functionality

I saw these risks during the Stage 1 risk analysis, architecture and security-design activities. The limited Postman PoC also showed the importance of defined validation checks by spotting the FHIR Content-Type configuration gap.

Planned Sprint Activities and Expected Major Deliverables for ICT946

Sprint	Main activities	Major deliverables
Sprint 1 – Core Test Harness Foundation	Confirm backend technology and development standards; configure Docker Compose; establish the Test Harness API; configure PostgreSQL synthetic-data storage; deploy/configure HAPI FHIR validation; load the agreed synthetic dataset; implement the initial FHIR Patient workflow; establish OperationOutcome error handling; create the automated test scaffold	Reproducible development environment; working core API; synthetic-data store; HAPI FHIR validation service; working FHIR Patient workflow; initial automated test framework; documented setup instructions
Sprint 2 – Integration, Security and Validation	Implement the seven planned failure-mode test cases; add slow-response, malformed-message, dropped-connection and unavailable-service simulations; implement synthetic-data validation rules; add authentication and	Automated functional and negative test suite; fault-injection capability; security controls; terminology-mapping validation results; pass/fail test report;

	tenant isolation; implement terminology-mapping test scenarios; automate result collection; perform functional and cybersecurity validation; document defects and regression results	cybersecurity evaluation; implementation documentation and demonstration
--	--	--

At the end of each sprint a sprint review will be held. Work that does not meet the agreed Definition of Done will remain open or return to the backlog rather than be reported as complete. I believe this process keeps the team honest.

Tools to be used

The implementation will use the technology stack that was chosen during Stage 1. Docker Compose will give Docker Compose an environment for multiple services ensuring that all developers work with identical setups. The backend will use the framework confirmed by the team at the start of ICT946. FastAPI/Python is currently the preferred option, while Express/Node.js remains an alternative identified during Stage 1. PostgreSQL will keep synthetic test records, mappings and test results while HAPI FHIR will give FHIR validation.

FHIR R4 and AU Core will be used for standards-based interoperability testing and HL7 v2 will stay for legacy-message simulations that still need it. SNOMED CT-AU, ICD-10-AM and MBS will be used for terminology-mapping tasks. Postman/Newman will help with API validation and PyTest or a similar testing framework will run repeatable automated tests.

GitHub will manage source control. Peer-reviewed pull requests while Jira will handle sprint planning, task ownership progress tracking and proof of individual contributions.

Development and configuration process

Implementation will follow a configuration and validation process, rather than building the entire solution all at once.

First our team will establish the shared repository branching approach, dependency versions and Docker Compose environment. Each service will then be configured individually and confirmed through health checks before being integrated with other components.

The core Patient workflow will be implemented first because Stage 1 has already shown the request-response behaviour through the Postman endpoint GET /fhir/R4/Patient/SYNTH-001. This gives the team a known baseline from which the production-like Stage 2 test environment can be developed. The core Patient workflow gives the team a starting point.

Once the core workflow is stable synthetic-data rules and FHIR validation will be introduced. Automated tests will then be added progressively beginning with requests, before moving to malformed data, slow responses dropped connections and unavailable-service conditions. Authentication, tenant isolation and other security controls will be implemented before -tenant testing.

Each increment will follow the same cycle:

Configure or develop → peer review → execute tests → compare expected and actual results → record defects → correct → regression test → document evidence.

A feature will only be considered complete when the implementation of that feature the testing of that feature and the supporting documentation, for that feature meet the Definition of Done.

Team contribution during ICT946

Stage 2 implementation will continue to use the domain responsibilities established during Stage 1.

Team member	Planned ICT946 contribution
Sonam Pelden – Project Lead / Architecture	Coordinate sprint priorities and scope, maintain architecture consistency, review dependencies and support final integration decisions
Charity Gwese – Clinical / Data	Review synthetic clinical scenarios, terminology accuracy and representative test data; support validation of expected clinical outcomes
Rikesh Aryal – Integration / Security	Support API, HAPI FHIR, container and connector integration; contribute to authentication, tenant isolation and other security controls
Zubair Adil Soomro – Testing / Documentation	Maintain the test strategy; implement or coordinate functional, negative and failure-mode tests; record expected versus actual outcomes; perform cybersecurity evaluation and regression testing; maintain testing evidence and implementation documentation

During ICT946 team members will review each other's pull requests and test results. This ensures that work is not accepted just because the person who wrote it says it is ready. Instead, another team member checks it. Sprint reviews will be used to see how well the delivered features match the Stage 1 requirements and success criteria. Every sprint log, in Jira will be kept. Task assignments, GitHub pull requests, screenshots and test outputs will also be saved. These items serve as proof of what was done. Can be added to the appendix if needed.

5.2 Testing, Validation, and Cybersecurity Evaluation

The proposed Stage 2 implementation will use a multi-service architecture that consists of a Test Harness API, PostgreSQL synthetic-data storage and HAPI FHIR validation. FastAPI and Python are the preferred backend options but the final backend framework will be confirmed at the start of ICT946. The planned synthetic dataset will contain 50 records that use SYNTH-prefixed identifiers, invalid test IHI and SNOMED CT-AU-coded conditions. HAPI FHIR is planned to provide validation against the agreed AU Core profiles. These components have not yet been implemented as a system; the Stage 1 technical evidence is limited to the Postman proof of concept described below.

Architecturally the Synthetic FHIR Test Harness lives inside a trust boundary that is completely separate from any real patient data environment as shown in Figure 1 – Asset & Trust Boundary Sketch Version 2. All requests go through one FastAPI entry point. The proposed architecture also includes a Tenant Isolation / Request Router. During Stage 2 the Tenant Isolation / Request Router will validate the `tenant_id` before routing requests, to the synthetic tenant environment. This Tenant Isolation / Request Router control is intended to prevent one practice from accessing another tenants' synthetic records. It has not yet been tested during Stage 1.

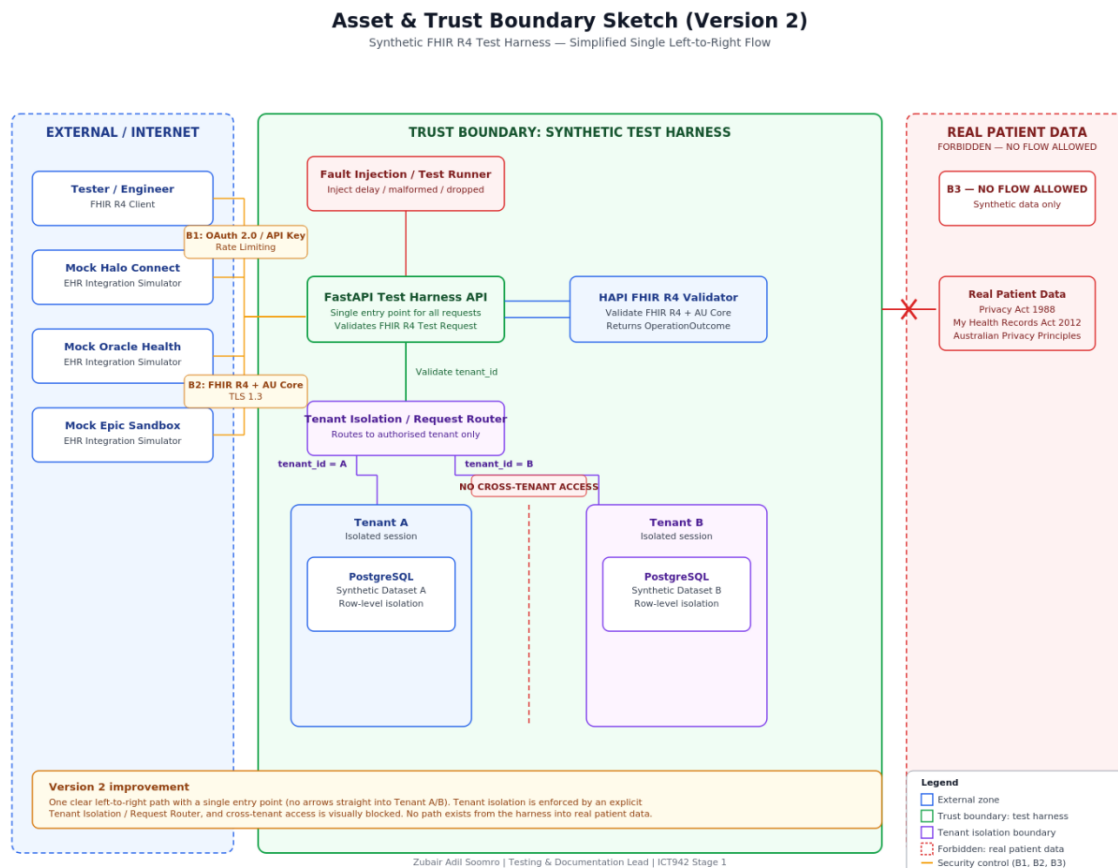


Figure 1 — Asset & Trust Boundary Sketch, Version 2

To keep the build safe the Proof of Concept chose one endpoint `GET /fhir/R4/Patient/SYNTH-001`. By week 8 this endpoint was set up. It ran as a mock server in Postman. It returns HTTP 200 OK with a structured synthetic FHIR Patient resource as shown In Figure 2 – Postman configuration and response. This is a working Proof of Concept configuration. It is not a Stage 2 build. Features such as HL7 v2.4 MLLP messaging SNOMED CT-AU mapping logic, rate limiting and negative-path fault injection are still planned for Stage 2 as originally intended.

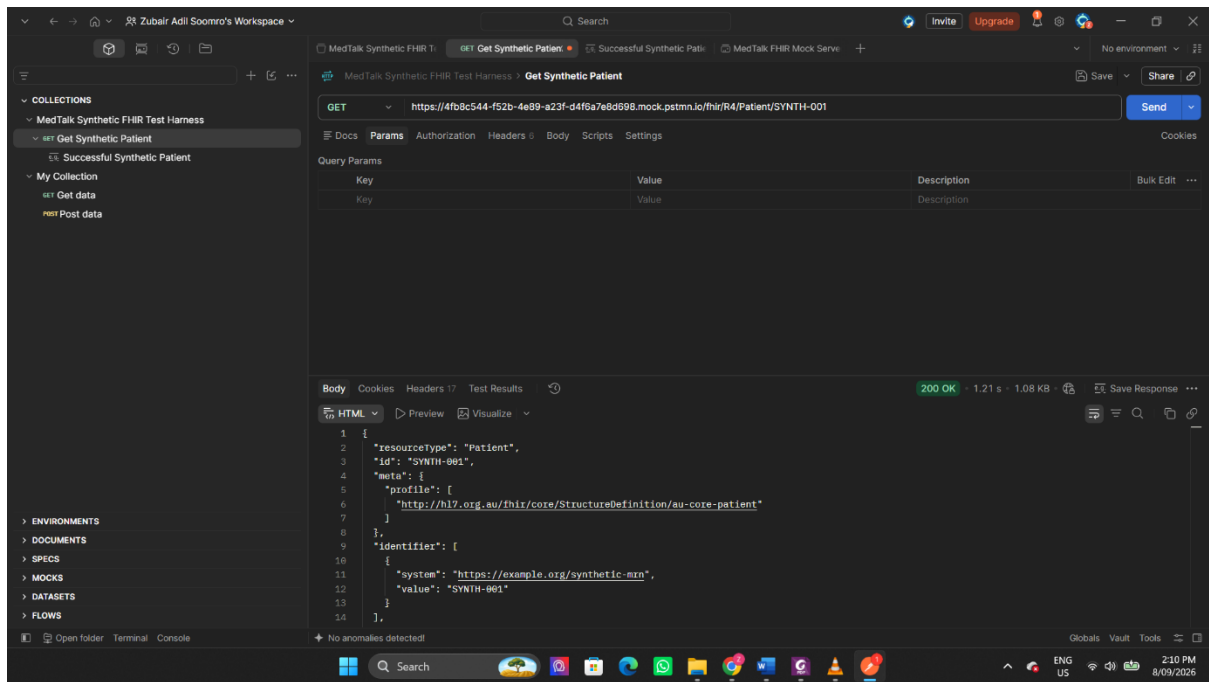


Figure 2 — Postman configuration and 200 OK response for GET /fhir/R4/Patient/SYNTH-001

During Stage 1 I found four assumptions that need to be checked during ICT946. Those architectural assumptions are Docker Compose orchestration, across development environments enforcement of DVR-01–DVR-08, programmatic AU Core validation using HAPI FHIR and consistent OperationOutcome handling using TH-001–TH-010. The Stage 1 Postman PoC checked the basic FHIR request-response flow and the expected Patient resource structure.

Testing at Stage 1 includes a set of functional tests that are run along with a larger set of tests designed for Stage 2. Three functional tests were run on the Postman mock of GET /fhir/R4/Patient/SYNTH-001 as shown in Table 1. Two of them passed. A HTTP 200 response and a correctly structured FHIR Patient resource that has the synthetic identifier SYNTH-001. And one failed: the response did not use the FHIR-specific application/fhir+json content type. This failure is reported on purpose because it shows that the process finds problems instead of just confirming success. The issue has been recorded for correction and regression testing during Stage 2 Sprint 1 in ICT946. The Stage 2 test report will follow the projects format for acceptance criteria: total tests run, pass rate, failures grouped by how bad they are, coverage of resources and endpoints a time stamp for the run and at least one documented example of a SNOMED-to-ICD-10-AM mapping edge case with the expected and actual results.

Table 1 — Functional Test Evidence (executed, Week 8)

Test ID	What is being tested	Expected	Actual	Result
TC-01	Successful HTTP response from the synthetic FHIR Patient endpoint	HTTP 200 OK	HTTP 200 OK returned	Pass
TC-02	Correct FHIR Patient resource and synthetic identifier	resourceType: Patient, id: SYNTH-001	resourceType: Patient, id: SYNTH-001 returned	Pass
TC-03	FHIR-specific response Content-Type	application/fhir+json	Returned successfully but without application/fhir+json	Fail

In addition to these three tests seven automated tests for failure modes are planned for Sprint 2: response (TC-SLOW-01/02) incorrect HL7/FHIR data (TC-MAL-01/02/03) a lost connection (TC-DROP-01) and a mock EMR that is not available (TC-UNAV-01) along with eight data-validation rules (DVR-01–DVR-08) and a ten-code error schema for OperationOutcome (TH-001–TH-010). TC-MAL-03 was added after a colleague noticed that synthetic data generation could accidentally create looking IHIs. A problem that was not in the original Week 5 risk register.

A Threat→Asset→Vulnerability→Impact→Control assessment shown in Table 2 shows how the main assets of the harness are connected to the threats: data leakage between tenants, errors in mapping SNOMED CT-AU to ICD-10-AM with NLP-based sensitivity as low as 54.1%; (Nguyen et al. 2018) and the risks of concentration and scaling that FAZ Australia’s Enterprise Product and Deployment Playbook already notes for MedTalk Connect. Specifically, that tenant isolation must work under real production conditions and be treated as a release requirement, not a one-time check. Table 3 shows how the current implementation status matches the NIST Cybersecurity Framework 2.0 controls using evidence that was shown in Stage 1. This approach is intentionally more conservative, than the proposed control design found in Section 4.3. Table 4 compares the risk that remains at the design stage against the risk expected after controls are put in place and tested.

Table 2 — Threat → Asset → Vulnerability → Impact → Control

Threat	Asset	Vulnerability	Impact	Control
Real patient data enters the test environment	Real patient records; compliance posture	Ad hoc validation historically run near/against live systems	Privacy Act 1988 / My Health Records Act 2012 breach; clinical-safety incident	Trust-boundary isolation (Boundary B3, no flow allowed); DVR-01–DVR-08 synthetic-only enforcement

Threat	Asset	Vulnerability	Impact	Control
Cross-tenant data access	Synthetic patient records (per tenant)	Flat trust boundary with no tenant separation (Risk R4 — Critical)	One mock practice's synthetic data exposed to another tenant's session	Tenant Isolation / Request Router validating tenant_id; row-level tenant_id foreign keys (planned)
Malformed or adversarial FHIR/HL7 payload	FastAPI Test Harness API; HAPI FHIR Validator	Connector may accept payload without structured rejection	Unhandled error or information disclosure via verbose stack trace	OperationOutcome error schema (TH-001–TH-010); TC-MAL test cases; AU Core conformance validation
Erroneous SNOMED CT-AU → ICD-10-AM/MBS mapping	Clinical terminology mapping logic	Automated mapping shown in literature to be error-prone (54.1% sensitivity; Nguyen et al., 2018)	Incorrect clinical documentation or billing if the same logic reached production	Dedicated mapping-validation test cases (Sprint 2); version-controlled mapping tables; manual review gate
Connector failure under adverse network conditions	MedTalk Connect ↔ mock EMR connection	Behaviour under slow, dropped or unavailable conditions not yet tested	Silent data loss or unhandled timeout if replicated against a live system	TC-SLOW / TC-DROP / TC-UNAV automated fault-injection test cases (Sprint 2)
Unauthorised access to the test harness	FastAPI Test Harness API	No authentication currently implemented (NIST PR.AA = Planned)	Unauthorised party could query or manipulate test data or results	Planned SMART on FHIR / OAuth 2.0 + API key at Boundary B1 (Sprint 2)

Section 4.3 describes the security controls that are meant for the target test-harness architecture, such, as authentication, encryption, input validation, logging and secure configuration. Section 5.2 checks these controls using the evidence that was shown during Stage 1. So, a control might be part of the suggested design. Still be listed here as Partial or Planned if the Stage 1 Postman proof of concept does not show any implementation evidence. This difference makes sure that controls that are planned for Stage 2 are not said to be done during Stage 1.

Section 4.3 control	Stage 1 evidence in Section 5.2	Evaluation for Stage 1
Authentication – SMART on FHIR / OAuth 2.0	Not demonstrated by the Postman mock endpoint	Planned – Stage 2
Data protection – synthetic data / identifier rejection	Synthetic SYNTH-001 data demonstrated; automated DVR enforcement not yet implemented	Partial

Encryption – HTTPS/TLS	No Stage 1 evidence demonstrating configured transport security	Planned Stage 2	–
Input validation – FHIR/message validation	Basic response structure was checked in Postman; HAPI/AU Core validation not yet implemented	Partial	
Logging and monitoring	Postman produced manual test evidence, but continuous security logging/monitoring is not implemented	Planned Stage 2	–
Secure configuration	Docker/container hardening has not yet been implemented	Planned Stage 2	–

Table 3 — NIST Cybersecurity Framework 2.0 Mapping

Control Reference	Control Name	How the component addresses it	Status
PR.DS	Data Security	The Stage 1 Postman PoC used synthetic patient information only, including the identifier SYNTH-001. This demonstrates the synthetic-data principle in a limited form. However, automated DVR enforcement, secure storage, encryption at rest and formal retention controls were not demonstrated during Stage 1.	Partial
PR.AA	Identity Management, Authentication and Access Control	Section 4.3 proposes SMART on FHIR/OAuth 2.0 authentication for the target architecture. The Stage 1 Postman mock endpoint did not implement or demonstrate authentication, RBAC or OAuth. These controls therefore remain implementation activities for Stage 2.	Planned
DE.CM	Continuous Monitoring	Stage 1 produced manual Postman test evidence and identified a real response-configuration defect. However, continuous event logging, security monitoring and automated alerting described in the target design were not implemented..	Planned

Table 4 — Before / After Risk Comparison

Threat	Current residual risk (Stage 1 design)	Projected residual risk (after Stage 2 controls implemented and tested)
Real patient data ingress	Low — mitigated by design discipline, not yet code-enforced	Low — enforced by automated DVR checks
Cross-tenant data access	High — identified (Risk R4), not yet built	Low — once Tenant Isolation / Request Router is implemented and tested

Threat		Current residual risk (Stage 1 design)	Projected residual risk (after Stage 2 controls implemented and tested)
Malformed payload handling		Medium — schema designed; one configuration gap already found (TC-03)	Low — once full TC-MAL suite passes
Terminology accuracy	mapping	High — mapping logic not yet built	Medium — residual risk not fully eliminable per published literature
Connector fault tolerance		High — untested under adverse conditions	Low — once TC-SLOW / TC-DROP / TC-UNAV suite executes
Unauthorised access to harness		High — no authentication implemented	Low — once OAuth 2.0 / API key at Boundary B1 is implemented

With regard to ethics, privacy and AI governance the PoC uses no personal or patient data; all fields are synthetic and there is no connection, to My Health Record. Two AI-related risks are listed. The first is that MedTalk is an AI scribe that automatically writes notes; an AI-generated note that is not checked and reaches this integration layer is an ethical and clinical safety issue that the harness is designed to catch before going to production. The second is that AI coding assistants helped with the projects documentation and learning; every technical result here was done and checked by hand which follows the Starter Kits AI usage policy. The one risk this review cannot fully handle is the problem of terminology mapping: even a harness that passes all the tests can't be sure it will work in every real-world situation because checking by hand only catches 76.3% of errors according to published research.

6. Conclusion and Recommendations

Stage 1 of this project has shown that a synthetic Australian-context test harness is both needed and possible for checking MedTalk Connect's connection with outside EMR systems before any connector reaches a live setting. Five findings support this conclusion. First the main technical risk is healthcare semantics – correctly applying the AU Core profile parsing HL7 v2 segments and converting SNOMED CT-AU to ICD-10-AM/MBS – not the age of the tools because Docker, FastAPI, HAPI FHIR and PostgreSQL are all mature and well documented and Docker Compose is the deployment pattern that FAZ Australia's own Playbook recommends for development and small-scale pilot environments. Second synthetic data creation has its privacy risk: if validation rules are not carefully set, generated identifiers can accidentally look like real ones, which is why DVR-01–DVR-08 and the Luhn-check rejection test (TC-MAL-03) exist. Third tenant isolation is an architectural requirement once the harness supports more than one mock practice and the current design only closes this gap on paper – a gap that matters more than it first appears because FAZ's own Playbook already lists scaling and tenant-isolation risk as a named operational concern for MedTalk Connect overall. Fourth the Week 8 Postman proof of concept proved that a minimal request-response loop can be achieved and importantly that structured testing reveals real defects as shown by the failed Content-Type test. Fifth comparing work against the NIST Cybersecurity Framework 2.0

shows that data-isolation practices are further ahead than access control and monitoring both of which remain planned rather than implemented. Although Section 4.3 describes the security controls proposed for the target architecture, for the design the Stage 1 test showed that only synthetic-data isolation and basic API validation were shown. Authentication, access control, continuous monitoring, secure configuration and other similar controls are still things that need to be done in Stage 2. Against the success criteria Stage 1 meets its design-stage objectives: an isolated architecture, a validated two-sprint plan a demonstrated single-endpoint PoC and a mapped set of security controls. It does not yet meet full-scale deployment readiness. Should not be presented as doing so. FAZ Australia's own Enterprise Product and Deployment Playbook defines a deployment as production-ready once branding is verified selected connectors pass health checks, authorised practitioners and scopes are configured a pilot has finished with an acceptable error rate, security and clinical-governance review is complete and an account owner is assigned. Measured against that checklist four gates should be satisfied before this harness reaches production-adjacent use: implementation and testing of the Tenant Isolation / Request Router with row-level `tenant_id` enforcement; implementation of authentication rate limiting and TLS 1.3 at the boundary, which is currently only planned under NIST PR.AA; execution of the full seven-case failure-mode suite with measured outcomes not only the three functional tests reported here; and the dedicated security and privacy review with the mentor raised at the Week 6 stand-up. Key limitations are the project's scope – a single FHIR resource and endpoint no real EMR connectivity, manual rather than automated testing – and the constraints of a small student team without dedicated DevOps resources. Future work should prioritise automating the test suite in CI adding human-in-the-loop review to terminology mapping given that manual coding validation itself reaches 76.3 % sensitivity, in the literature and once trusted, supporting FAZ's stated priority of a second reference customer rather than leaving production evidence concentrated in one deployment.

References

Attorney-General's Department. (n.d.). Document Verification Service (DVS). Australian Government. <https://www.idmatch.gov.au/resources/identity-verification-services-privacy-statement>

Australian Government. (1988). Privacy Act 1988 (Cth). <https://www.legislation.gov.au/Details/C2022C00361>

Australian Government. (2012). My Health Records Act 2012 (Cth). <https://www.legislation.gov.au/Details/C2017C00313>

Bonami Software. (2026). *Epic Integration & Implementation*. Bonami Software. <https://www.bonamisoftware.com/epic-integration>

Choudhary, J. (2026). *How to Get Your App Into Epic* (2026). Nirmitee.Io. <https://nirmitee.io/blog/how-to-get-your-app-into-epic/>

eCQI. (2025). *FHIR® - Fast Healthcare Interoperability Resources® - About* | eCQI Resource Center. Healthit.Gov. <https://ecqi.healthit.gov/fhir/about>

FAZ Australia. (n.d.). Project brief and requirements specification [Unpublished internal document].

For practices - Halo Connect Documentation. (2026). Haloconnect.Io. <https://docs.haloconnect.io/guides/practice-guide/>

Giannangelo, K., et al. (2012). Mapping SNOMED CT to ICD-10. *Studies in Health Technology and Informatics*, 180, 83–87. <https://pubmed.ncbi.nlm.nih.gov/22874157/>

Gruendner, J., Gulden, C., Kampf, M., Mate, S., Prokosch, H.-U., & Zierk, J. (2021). A framework for criteria-based selection and processing of Fast Healthcare Interoperability Resources (FHIR) data for statistical analysis: Design and implementation study. *JMIR Medical Informatics*, 9(4), e25645. <https://doi.org/10.2196/25645>

HL7 Australia. (n.d.). AU Core Implementation Guide (v1.0.0). HL7 International. <http://hl7.org.au/fhir/core/>

HL7 International. (2019). HL7 FHIR Release 4 (R4). <https://hl7.org/fhir/R4/>

MarkiTech.AI. (2025,). MarkiTech. <https://markitech.ca/our-work-healthcare/> accessed 09 September 2026.

MediBetter | Integrations. (2026). Medibetter.Com.Au. <https://medibetter.com.au/integrations/>

MediRecords Connect: Getting Started with Connect & FHIR APIs. (2026). Knowledge Base. <https://support.medirecords.com/hc/en-us/articles/13936381648399-MediRecords-Connect-Getting-Started-with-Connect-FHIR-APIs>

MedTalk AI. (2020). *AI Medical Scribe Features in Australia.* MedTalk AI. <https://medtalk.co.au/product>

National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0 (NIST CSWP 29). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.CSWP.29>

SMART Health IT. (n.d.). SMART App Launch Framework. HL7 International. <https://hl7.org/fhir/smart-app-launch/>

SMART on FHIR. (n.d.). Docs.Smarthealthit.Org. Retrieved September 11, 2026, from <https://docs.smarthealthit.org/>

SNOMED CT-AU and Australian Medicines Terminology May 2022 Release. (2022). Digitalhealth.Gov.Au. <https://www.digitalhealth.gov.au/healthcare-providers/product-releases/snomed-ct-au-and-australian-medicines-terminology-may-2022-release>

Synapxe - HealthX Innovation Sandbox. (2023). Healthx.Sg. <https://innovation.healthx.sg/>

Walonoski, J., Kramer, M., Nichols, J., Quina, A., Moesel, C., Hall, D., Duffett, C., Dube, K., Gallagher, T., & McLachlan, S. (2018). Synthea: An approach, method, and software mechanism for generating synthetic patients and the synthetic electronic health care record.

Journal of the American Medical Informatics Association, 25(3), 230–238.
<https://doi.org/10.1093/jamia/ocx079>

FAZ Australia. (2026). Healthcare Integration & Clinical Terminology Test Harness: Project starter kit [Unpublished project brief]. Crown Institute of Higher Education.

FAZ Australia. (2026). MedTalk Connect: Enterprise product and deployment playbook [Unpublished company document]. Crown Institute of Higher Education.

HL7 Australia. (2023). AU Core FHIR implementation guide (v0.2.0-preview).
<https://hl7.org.au/fhir/core/0.2.0-preview>

Nguyen, A. N., Truran, D., Kemp, M., Koopman, B., Conlan, D., O'Dwyer, J., et al. (2018). Computer-assisted diagnostic coding: Effectiveness of an NLP-based approach using SNOMED CT to ICD-10 mappings. AMIA Annual Symposium Proceedings, 2018, 807–816.

Pascoe, C., Quinn, S., & Scarfone, K. (2024). The NIST Cybersecurity Framework (CSF) 2.0 (NIST CSWP 29). National Institute of Standards and Technology.
<https://doi.org/10.6028/NIST.CSWP.29>

Walonoski, J., Scanlon, R., Dowling, C., Hyland, M., Ettema, R., & Posnack, S. (2018). Validation and testing of Fast Healthcare Interoperability Resources standards compliance: Data analysis. JMIR Medical Informatics, 6(4), e10870. <https://doi.org/10.2196/10870>

Appendix

The screenshot shows a Jira workspace interface. The left sidebar contains navigation options like 'For you', 'Recent', 'Starred', 'Apps', 'Spaces', and 'Teams'. The main area displays the 'ICT942 Healthcare Integration Test Harness' workspace with a list view of tasks. The tasks are organized in a table with columns for 'Work', 'Assignee', 'Reporter', and 'Priority'.

Work	Assignee	Reporter	Priority
☐ HETH-49 Presentation Slides	Unassigned	Sonam PELDEN	Medium
☐ HETH-48 Executive Summary	Zubair Adil Soomro	Sonam PELDEN	Medium
☐ HETH-47 Conclusion and Recommendations	Zubair Adil Soomro	Sonam PELDEN	Medium
☐ HETH-46 Testing, Validation, and Cybersecurity Evaluation/evaluate ethical and...	Zubair Adil Soomro	Sonam PELDEN	Medium
☐ HETH-45 Proof of Concept Description	Zubair Adil Soomro	Sonam PELDEN	Medium
☐ HETH-44 Risk Register and Feasibility Study	Sonam PELDEN	Sonam PELDEN	Medium
☐ HETH-43 Capital and Non-Capital Cost Estimation	Rikesh ARYAL	Sonam PELDEN	Medium
☐ HETH-42 Security Design and Control Mapping	Rikesh ARYAL	Sonam PELDEN	Medium
☐ HETH-41 Gap Analysis: As-Is to To-Be	Charity	Sonam PELDEN	Medium